

NIST CSF 2.0 RISK ASSESSMENT

Executive Report — Northbridge Kitchen Supply Co.

Prepared July 2026 • Fictional exercise, built for portfolio purposes

Northbridge Kitchen Supply Co. is a fictional company invented for this self-directed exercise. No real organization was assessed, and no finding in this report describes a real entity or real data.

Executive Summary

This report presents the results of a NIST Cybersecurity Framework (CSF) 2.0 risk assessment conducted against Northbridge Kitchen Supply Co., a 42-person B2B distributor of commercial kitchen equipment. The company has no in-house security function — an Operations Manager handles IT part-time, supported by an outsourced MSP for helpdesk support.

The assessment scored 35 representative subcategories spanning all six CSF 2.0 Functions (Govern, Identify, Protect, Detect, Respond, Recover) against Northbridge's current practices and a realistic target for a company of its size. The overall picture is a company with almost no formal cybersecurity program: average current maturity across all 35 subcategories is 0.23 on a 0–3 scale, against a realistic target of 1.46. Ten findings scored in the Critical band.

The good news: nearly every gap identified has a low-cost, achievable fix. None of the recommended actions in this report require new headcount or major capital spend — they require someone to own them and a leadership team willing to spend a few hours making decisions that, right now, nobody has been asked to make.

Methodology

Each of the 35 subcategories was scored on Current State and Target State (Not Implemented / Partially Implemented / Largely Implemented / Fully Implemented), then assessed for risk using a Likelihood × Impact model (1–5 each, producing a 1–25 Risk Score). Scores of 15+ are rated Critical, 10–14 High, 5–9 Medium, and 1–4 Low. The 35 subcategories were deliberately scoped — proportional to each Function's real weight in the full 106-subcategory framework — rather than assessed at full depth, which is a standard time-boxing approach for an initial assessment.

Full scoring detail, including every subcategory, its gap, and its recommended action, is provided in the companion workbook (Northbridge-NIST-CSF-2.0-Risk-Assessment.xlsx).

Maturity Heatmap by Function

Average current maturity by Function, scored 0 (Not Implemented) to 3 (Fully Implemented). Redder cells indicate a larger gap to target.

Function	Subcats	Avg Current (0-3)	Avg Target (0-3)	Critical	High
Govern	10	0.20	1.40	1	6
Identify	7	0.14	1.43	2	1
Protect	7	0.71	2.00	4	1
Detect	4	0.00	1.00	1	0
Respond	4	0.00	1.50	2	0
Recover	3	0.00	1.00	0	1
All Functions	35	0.23	1.46	10	9

Govern and Identify are the weakest Functions — expected for a company with no formal security ownership. Protect is comparatively less weak, largely because Microsoft 365 and Stripe provide baseline capability out of the box, not because Northbridge has built anything itself. Detect, Respond, and Recover are effectively at zero: if something goes wrong, Northbridge currently has no way to notice quickly, no plan for responding, and no tested way to recover.

Top 10 Risks

The following ten findings scored in the Critical band (Risk Score 15+) and represent the highest-priority gaps identified.

ID	Function	Risk (plain English)	Score	Priority
ID.AM-07	Identify	No inventory of where customer PII and payment data actually lives or flows.	20	Critical
GV.SC-01	Govern	No strategy for managing risk from suppliers (3PL, hosting, Salesforce, Stripe).	16	Critical
ID.RA-01	Identify	The customer-facing ordering portal has never been vulnerability-scanned.	16	Critical
PR.AA-02	Protect	MFA is not enforced for all M365 accounts, including remote staff.	16	Critical
PR.PS-01	Protect	No confirmed process for keeping the WooCommerce/WordPress portal patched.	16	Critical
DE.CM-01	Detect	No monitoring in place to notice a compromise while it's happening.	16	Critical
PR.AT-01	Protect	Staff have never received phishing-awareness training.	15	Critical
PR.DS-01	Protect	Encryption of stored customer and payment data has never been verified.	15	Critical
RS.MA-01	Respond	No written incident response plan exists.	15	Critical
RS.CO-02	Respond	No process for notifying customers or regulators after a breach.	15	Critical

Remediation Roadmap

Recommended actions are grouped into three horizons based on effort and dependency, not just severity — several Critical findings have genuinely 30-day fixes, while some Medium findings depend on other work completing first.

Quick wins — 30 days *(8 actions)*

- Draft a 1-page cybersecurity risk statement tied to business priorities (GV.OC-01).
- Hold a leadership session to agree on 3–5 risk management objectives (GV.RM-01).
- Document a RACI matrix for security tasks across Ops Manager, MSP, and IT contractor (GV.RR-01).
- Build a vendor list with a one-page risk note per supplier (GV.SC-01).

- Build a single SaaS application inventory (ID.AM-02).
- Map where customer PII and payment data flows end to end (ID.AM-07).
- Document an offboarding checklist for M365, Salesforce, and 3PL access (PR.AA-01).
- Enforce MFA for all M365 accounts via Conditional Access (PR.AA-02).

Medium-term — 90 days *(12 actions)*

- Compile an inventory of regulatory and contractual cybersecurity obligations (GV.OC-03).
- Adopt and distribute an acceptable-use and data-handling policy (GV.PO-01).
- Tier vendors into Critical vs Standard risk (GV.SC-04).
- Validate a complete hardware asset inventory via the MSP (ID.AM-01).
- Commission a basic external vulnerability scan of the ordering portal (ID.RA-01).
- Roll out annual phishing-awareness training to all staff (PR.AT-01).
- Confirm encryption-at-rest practices with Stripe, the 3PL, and the web host in writing (PR.DS-01).
- Confirm a monthly patch cadence for the WooCommerce/WordPress portal (PR.PS-01).
- Confirm M365 audit logging is enabled and retained 90+ days (PR.PS-04).
- Close monitoring gaps with the MSP for adverse-event detection (DE.CM-01).
- Draft a 2-page incident response plan (RS.MA-01).
- Identify breach-notification requirements and add timelines to the IR plan (RS.CO-02).

Long-term — 180 days *(15 actions)*

- Define a risk tolerance statement; add a standing leadership cybersecurity review (GV.RM-03, GV.OV-01).
- Add a security questionnaire to vendor onboarding (GV.SC-06).
- Make this risk assessment an annual, repeatable process (ID.RA-05, ID.IM-01).
- Publish a responsible-disclosure contact (ID.RA-08).
- Confirm hosting SLA and scaling plan; enable endpoint change monitoring (PR.IR-04, DE.CM-09).
- Define what counts as an investigable incident (DE.AE-02, DE.AE-03).
- Add severity tiers and containment steps to the IR plan (RS.MA-03, RS.MI-01).
- Add a recovery plan section and test-restore backups annually (RC.RP-01, RC.RP-03).
- Add a customer-facing outage communication template (RC.CO-03).

Closing Note

This assessment is a self-directed, fictional exercise built to practice and demonstrate the NIST CSF 2.0 methodology end to end — scoping, scoring, prioritizing, and translating findings into an executive-readable roadmap. The same process applies directly to a real organization; the only thing that would change is the underlying facts.